

Cyber-risk guidance from the SEC: New realities for a new level of threat



Cyber-lawlessness: Welcome to the Wild Wild Web

It seems that nearly every day we hear of another successful cyber attack on a highly visible organization. Indeed, data breaches of just about every type are on the rise — in frequency, sophistication, and risk impact. From personal financial and healthcare information to intellectual property and trade secrets, these breaches show no sign of abating.

This new reality of heightened cyber-threats appears to be enabled by several converging factors, both internal and external. In the absence of adequate due diligence and ongoing monitoring, third-party vendors and agents continue to elevate risk. And, while regulation aims to set a standard of mandatory minimums, the gap between that minimum and meaningful risk management can be substantial.

Many companies do not adequately grasp the degree of threat their organizations face. Certain nation-states see cyber-theft and even cyber-sabotage as a beneficial global economic competitive tool. Transnational organized criminals — sometimes in concert with nation-states, sometimes acting alone — continue to score massive attacks against a wide variety of targets.

Few organizations are immune. Virtually any company that possesses intellectual property, sensitive employee or customer data, or other information considered valuable can be a target. Beyond theft, the targeted data can be used to launder money through unregulated money transmitters in various foreign countries — or even used for extortion or scams.

Given the level of lawlessness, many pundits describe today's cyber attacks as reminiscent of the Wild Wild West. And they may well be right. Today's Web is a happy hunting ground for parties who are willing to violate virtually any law, statute or ethical edict to penetrate even some of the supposedly best-protected defenses.

Cybersecurity is not just “an IT thing.” It’s also a governance thing. (Just ask the SEC.)

Compounding the problem is the fact that many boards and managements still perceive cybersecurity as essentially “an IT thing.” Not only does this perception increase an organization's potential exposure to attack, it also widens the communications gap between those charged with protecting the enterprise and those whose obligations are ensuring a return to investors and shareholders, and maintaining strong corporate governance.

But with the kinds of damage being regularly wrought through successful, high-profile cyber-attacks, governance is very much the point. After all, it's not just businesses and their customers that are on the hook. In an era where digital assets hold an ever greater share of a company's market value, investors, too, have a vested interest in knowing how — and how well — companies are managing their cyber-operational risks.

Both U.S. states and foreign governments and regulators have responded to this increasingly pressing issue with a variety of data breach laws and/or regulations intended to protect consumer information. The U.S. Securities and Exchange Commission, too, has recently issued updated guidance applicable to SEC registrants.

These guidelines, arguably, represent the next frontier of legal and forensics advice. Not only will they create SEC enforcement risk, they could serve as a useful yardstick for the class action bar in seeking to prove liability. Thus, they constitute a strong signal that companies need to take their cybersecurity efforts seriously.

The regulatory tea leaves suggest that, with the accelerating risk that cyber-threats now pose to shareholders and investors, the SEC will assume more and more prominence in this space. Responding to SEC guidance is therefore gaining board-level traction.

Unfortunately, the task of meaningfully describing in public filings the potential risk — and, in the event of a breach, the potential impact on the securities — is challenging for many registrant boards and executives, even those who have already felt the sting of a cyber-attack.

Cyber-risk guidance: Get ready for the next wave of SEC regulation

The SEC guidance¹ states that “registrants should disclose the risk of cyber incidents if these issues are among the most significant factors that make an investment in the company speculative or risky.” The SEC is prescriptive about what companies should take into consideration when assessing cyber-risk: “In determining whether risk factor disclosure is required, we expect registrants to evaluate their cybersecurity risks and take into account all available relevant information, including prior cyber incidents and the severity and frequency of those incidents.”

The guidance goes on: “As part of this evaluation, registrants should consider the probability of cyber incidents occurring and the quantitative and qualitative magnitude of those risks, including the potential costs and other consequences resulting from misappropriation of assets or sensitive information, corruption of data or operational disruption.”

Beyond disclosure, companies also need to accrue for — and disclose — the costs of a breach in a timely manner. Failure to do so can create significant whistleblower risk, which the SEC’s bounty program exacerbates.

Here are some of the specific factors cited by the SEC, which registrants would be wise to consider in assessing the degree of cyber-risk they face:

- *The adequacy of preventative actions taken to reduce cybersecurity risks, in the context of the company’s industry.* Clients often misjudge adequacy based on the perception that their enterprises are not targeted, and misjudge security requirements based on peer groups.
- *Threatened attacks of which the company is aware, including incidents experienced by the registrant that are individually or, in the aggregate, material.* This raises the issue not only of what attacks the company is aware of, but of what it is doing to identify attacks.
- *Which aspects of business or operations give rise to material cybersecurity risks.* Materiality is not always obvious — especially when considering the compromise of intellectual property, trade secrets and other issues which could possibly imperil the brand and, therefore, its value in the market.
- *The potential costs and consequences of such material risks.* There are many variables here. The loss of personal information in a data breach may involve different costs than, say, the loss of intellectual property and trade secrets.

Suppose that a client has a data breach that includes the compromise of financial account information and other personal identifiers. Then consider the client that, as a result of the breach, has lost the R&D details of some great new technology — the next big thing. Then consider that investment partners who also funded the development of the technology. Then, there’s the question of how much revenue the technology was forecasted to deliver over a specified period. And what if the attackers used virtually unbreakable, military-grade encryption, making the technology unavailable to its rightful developers and owners? And what if the attack was launched by a nation-state planning to compete with the client on a global scale, stealing not only its technology but the majority of its market share?

- *To the extent the registrant outsources functions that have material cybersecurity risks, a description of those functions and how the registrant addresses those risks.* This point is particularly important, as third-party vendors are often the entry point in an attack on a registrant.
- *Risks related to cyber-incidents that may remain undetected for an extended period.* Leading breach indicators are sometimes missing for many years (up to six or seven years is not uncommon), making the identification of risk factors a significant challenge for a company.
- *Relevant insurance coverage.* This is a key emerging issue for many clients, who need continuing counsel as threats evolve and as insurance policies adapt to changing conditions.

¹ Securities and Exchange Commission, Division of Corporation Finance, CF Disclosure Guidance: Topic No. 2, Cybersecurity (October 13, 2011), <http://www.sec.gov/divisions/corpfin/guidance/cfguidance-topic2.htm>

Providing the right advice: It's complicated

Addressing the many issues in this SEC guidance is easier said than done. Many registrants will need help determining what, how, and when to disclose information regarding the potential for a cyber attack — and how such an attack might impair their operations and valuation. Sophisticated legal and forensics advice is needed to substantively and accurately address pre- and post-breach concerns, including determining materiality.

One useful method for helping registrants assess the legal, regulatory, financial, and reputational risk is to conduct an analysis from a post-breach perspective. This is an opportunity for counsel to assess the client's disclosure strategy. Simply looking at the registrant's information security deployment is not sufficient to fully understand its overall risk, and what to disclose, for example, in its 10K filing with the SEC.

But using actual forensic data results, acquired through cyber-breach indicator testing and/or through any registrant's prior breach data — including data from other companies whose cyber-breaches are part of the public record — can provide a realistic view into the breach and its consequences.

But a word of caution here. Breach cases can be extremely variable; companies report various — but certainly not all — aspects of breaches. While certain general conclusions may be drawn, there are important limitations to what can be learned from the public record. Still, understanding as much as possible about the nature of the threat and the resulting breach is always useful when developing a strategy to manage cyber-risk. From there, you can learn how to manage the breach effectively, and how to report critical elements of it as part of an overall strategy to manage risk.

On the plus side, there is growing interest in the National Institute of Standards and Technology (NIST) Cyber Security Framework, a public-private initiative that will hopefully lead to improved security. The NIST framework will help registrants move in a single direction — a beneficial step as companies prepare to develop plans to mitigate and recover from breaches, and a demonstration of reasonable cyber-risk management.

Continuous improvement: The next level of compliance

It's clear that the Internet, Cloud, mobile, and various other technologies are greasing the wheels for the propagation of cyber-crimes of all kinds. It's equally clear that security is not likely to outpace the innovation that enables advances in productivity and cost savings — the very virtues that make companies desirable targets. Cyber attacks are not going away.

Viewed in this context, the new SEC guidance on cyber-disclosure is a natural evolutionary step in addressing this systemic risk. Fortunately, there is evidence that registrants are starting to take it seriously.

Still, it is only a step. Compliance alone is not a silver bullet. It should be viewed as the cornerstone of a new framework for managing registrant risk — one that embeds both vigilance and continuous improvement into corporate strategy — in cooperation with regulators and forward-thinking entities such as NIST.

It can be challenging for a public company to incorporate these kinds of evolutionary process improvements into their business strategies while navigating the full range of cyber-risks alone. This is where seasoned attorneys and forensic specialists have a critical role to play. In the matter of the SEC and its registrants v. the cyber-threat, independent, experienced advice can make a significant difference.

For a deeper discussion, please contact:

MacDonnell Ulsch,
Managing Director, Cybercrime & Breach Response
PwC
Tel: +1 617 530 6390
Email: don.ulsch@us.pwc.com

The first publication of this article is attributed to the American Bar Association's Criminal Justice Section Newsletter, Winter 2015 issue.